

Security+ 2.4 · Indicators of Compromise

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.4 — Indicators of Compromise (10:59) · [vídeo original ↗](#) · [YouTube ↗](#)

IOC: sinal de comprometimento — account lockout em série (spraying); impossible travel (login NY/Bangalore em 10 min); resource consumption anormal (CPU/exit de rede); hora atípica; baseline deviation. IOC = IP malicioso, hash, domínio. Defesa: EDR/SIEM correlacionando, threat feed, alerta de horário.

💡 Highlights que a prova cobra

- IOC = IP malicioso, hash de malware, domínio de C2 — pista técnica
- Impossible travel = login geograficamente impossível na JANELA de tempo
- Account lockout em série = brute force/spraying em curso

🎯 Dicas de prova

- 'login from two distant locations within minutes' = impossible travel (IOC)
- 'IP address known to be malicious' = IOC

Cenário clássico: Cenário: 'usuário faz login de São Paulo às 9h e de Lisboa às 9h05' = impossible travel (indício de comprometimento).

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:

- A) OWASP Top 10
- B) MITRE ATT&CK
- C) ISO 27001
- D) PCI-DSS

2. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

```
3. x = 5\\ndef change():\\n    global x\\n    x = 10\\nchange()\\nprint(x)
```

- A)** 5
B) 10
C) Erro
D) None

4. Cenário corporativo (Indicators of Compromise): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'IOC = IP malicioso, hash de malware, domínio de C2 — pista técnica'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: IOC = IP malicioso, hash de malware, domínio de C2 — pista técnica...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Indicators of Compromise): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Impossible travel = login geograficamente impossível na JANELA de tempo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Impossible travel = login geograficamente impossível na JANELA de tempo...

6. Cenário corporativo (Indicators of Compromise): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Account lockout em série = brute force/spraying em curso'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Account lockout em série = brute force/spraying em curso...

7. Cenário corporativo (Indicators of Compromise): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'login from two distant locations within minutes' = impossible travel (IOC). Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'login from two distant locations within minutes' = impossible travel (IOC)...

8. Cenário corporativo (Indicators of Compromise): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'IP address known to be malicious' = IOC. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'IP address known to be malicious' = IOC...

9. Cenário corporativo (Indicators of Compromise): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'usuário faz login de São Paulo às 9h e de Lisboa às 9h05' = impossible travel (indício de comprometimento)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário: 'usuário faz login de São Paulo às 9h e de Lisboa às 9h05' = impos...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Indicators of Compromise): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'IOC = IP malicioso, hash de malware, domínio de C2 — pista técnica'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: IOC = IP malicioso, hash de malware, domínio de C2 — pista técnica...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

1) B — MITRE ATT&CK. MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão.

2) B — Identificar, Proteger, Detectar, Responder, Recuperar. NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na

3) B — 10. A palavra-chave global permite modificar a variável x do escopo global dentro da função.

4) C — Implementar a solução correspondente: IOC = IP malicioso, hash de malware, domínio. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Indicators of Compromise): IOC = IP malicioso, hash de malware, domínio de C2 — pista técnica. As demais alternativas configuram violaç

5) D — Implementar a solução correspondente: Impossible travel = login geograficamente . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Indicators of Compromise): Impossible travel = login geograficamente impossível na JANELA de tempo. As demais alternativas configuram v

6) D — Implementar a solução correspondente: Account lockout em série = brute force/spr. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Indicators of Compromise): Account lockout em série = brute force/spraying em curso. As demais alternativas configuram violações graves

7) D — Implementar a solução correspondente: 'login from two distant locations within m. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Indicators of Compromise): 'login from two distant locations within minutes' = impossible travel (IOC). As demais alternativas configur

8) D — Implementar a solução correspondente: 'IP address known to be malicious' = IOC... Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Indicators of Compromise): 'IP address known to be malicious' = IOC. As demais alternativas configuram violações graves de conformidade

9) B — Implementar a solução correspondente: Cenário: 'usuário faz login de São Paulo à. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Indicators of Compromise): Cenário: 'usuário faz login de São Paulo às 9h e de Lisboa às 9h05' = impossible travel (indício de comprome

10) A — Implementar a solução correspondente: IOC = IP malicioso, hash de malware, domínio. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Indicators of Compromise): IOC = IP malicioso, hash de malware, domínio de C2 — pista técnica. As demais alternativas configuram violaç

